

MaGMa 2.0

Use case framework

MaGMa UCF 2.0



Version	1.0
Date	25.09.2026
Author	Rob van Os

Contents

1	Introduction	4
1.1	Developments	4
1.2	Purpose of MaGMa UCF	4
1.3	Is MaGMa UCF still relevant?	4
2	MaGMa 1.0 - summary	6
2.1	Model	6
2.2	MaGMa - Management	7
2.3	MaGMa - Growth	7
2.3.1	Setting direction	8
2.3.2	Setting priorities	8
2.4	MaGMa - Metrics & assessment	9
3	MaGMa 2.0	10
3.1	Model	10
3.1.1	Unified Kill Chain	11
3.1.2	Calculations	11
3.2	Management & Growth	13
3.3	Metrics & assessment	13
3.4	Interrelationships	15
3.4.1	Risk analysis	16
3.4.2	Visibility	16
3.4.3	Detection quality	16
3.5	Development	17
4	Limitations and best practices	18
4.1	Current limitations	18
4.2	Best practices for conducting an assessment	18
5	PRISMA Tool	20
5.1	PRISMA tool components	20
5.2	Saving and exporting	21
6	Annex A: DeTT&CT data quality indicators	22
	Annex B: PRISMA tool visualisations	23
	DeTT&CT heatmap	23
	DeTT&CT Insights	24
	MaGMa L1, L2, L3	25
	MaGMa heatmap	26
	MaGMa Insights	27

MaGMa summary	27
---------------------	----

1 Introduction

The MaGMA Use Case Framework (UCF) was introduced in 2017. The framework was the result of collaboration between several financial institutions within the FI-ISAC that wanted to share security monitoring use cases between their security operations centres (SOCs). However, the framework has not been maintained since its initial publication in 2017.

1.1 Developments

Over the past 10 years, significant developments have affected the currency of the MaGMA framework. The main developments are:

- **The continued development of the MITRE ATT&CK®** framework, particularly as a standalone methodology for ‘defensive gap analysis’: mapping the current state of detection against the desired state.
- **The development of more comprehensive kill chains**, such as the Unified Kill Chain, which combines the Lockheed Martin Kill Chain with MITRE ATT&CK® and can represent a much more detailed attack chain. In the Lockheed Martin Kill Chain, a very large part of the attack falls under ‘actions on objectives’.
- **A high degree of automation within SOC processes**. The original version of MaGMA UCF relied on maintaining an Excel file. This is no longer appropriate for a modern security operations centre.

1.2 Purpose of MaGMA UCF

The purpose of the MaGMA Use Case Framework is to provide insight into the quality of monitoring. This can prevent situations in which monitoring is in place but is not sufficiently effective at detecting threats, resulting in incidents that could have been prevented. The results of MaGMA assessments (and DeTT&CT assessments) can be used to develop roadmaps, set priorities and make investment decisions. This enables improvements to monitoring and addresses potential blind spots or broader shortcomings in infrastructure visibility from a cybersecurity perspective. The ultimate goal is to make cyber resilience within the SOC quantifiable and improve it.

1.3 Is MaGMA UCF still relevant?

An important question is whether MaGMA UCF remains relevant in today's security operations centres, with their use of AI and automation and strong focus on MITRE ATT&CK® to assess detection coverage. Despite these developments, it is important to recognise that MaGMA's core principles still apply in a modern security operations centre. Without use case management, security monitoring detections lack a broader context and remain confined to the technical domain. Use case management establishes the link between detections and business objectives, and MaGMA's principles and model remain valuable. MaGMA 2.0 is an updated version of MaGMA UCF that fits within a modern security operations centre.

For organisations where detection is largely driven by standardised agents with limited configuration options, use case management remains relevant, but detection engineering (creating and maintaining detection rules internally) is less relevant. In such a setup, applying MaGMA UCF offers less added value. MaGMA's value is particularly evident when the SOC team develops and improves detections itself. Even without detection engineering, the link to risks remains relevant. Organisations that outsource their SOC can also benefit from applying

MaGMA to the set of detections made available to them. This provides insight into how much value security monitoring adds to the organisation.

2 MaGMa 1.0 - summary

MaGMa stands for **M**anagement, **G**rowth, **M**etrics and **a**ssessment. These 3 components describe the main elements of the framework. It is also important to understand the MaGMa model, particularly its layered structure. This chapter explains the basics of MaGMa 1.0. Further information can be found in the original document and the white paper [1].

2.1 Model

The key aspect of the MaGMa model is that use cases are approached at 3 layers:

- **The business / risk layer (L1).** This layer describes the business risk monitored through the use case. It is essential for linking operational security monitoring to risks and tangible value for the organisation. In the original version of MaGMa, the business layer consisted of aggregated scores for each phase of the Lockheed Martin Kill Chain, supplemented by specific risks that could be linked directly at L2/L3.
- **The tactical layer (L2).** This layer describes how the risk defined at L1 can manifest itself. It is aligned with the tactics in MITRE ATT&CK® and extended with logical groups that are not related to MITRE tactics.
- **The detection layer (L3).** This layer contains the technical detection rules used to perform monitoring. Where applicable, the mapping to MITRE ATT&CK® is established at this layer. Assessment (see Metrics & assessment) is also performed at L3.

A simplified MaGMa model is shown below. A more detailed model can be found in the original documentation.

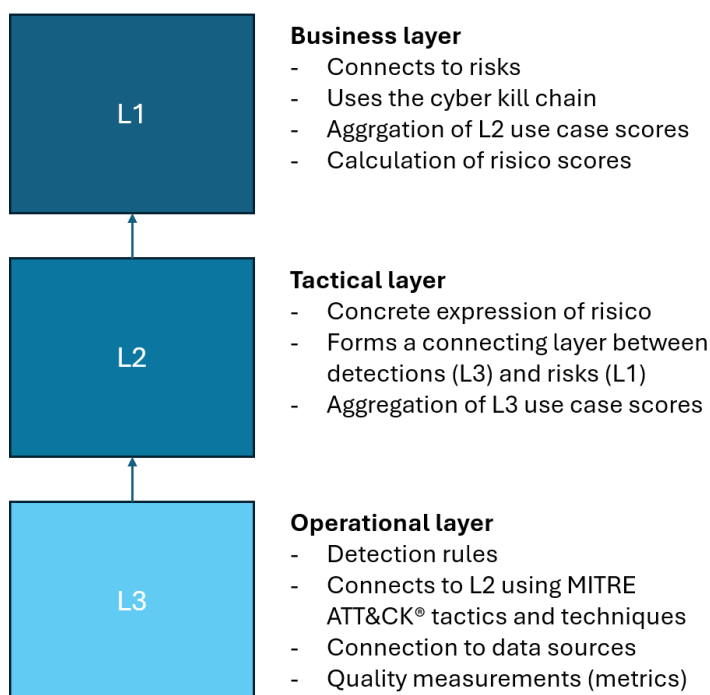


Figure 1: simplified MaGMa model

¹ [MaGma](#)

2.2 MaGMa - Management

The first element of MaGMa describes managing the use case throughout its lifecycle: from the initial creation of use cases to regular maintenance and, ultimately, the retirement of use cases that are no longer needed. MaGMa visualises this as follows:

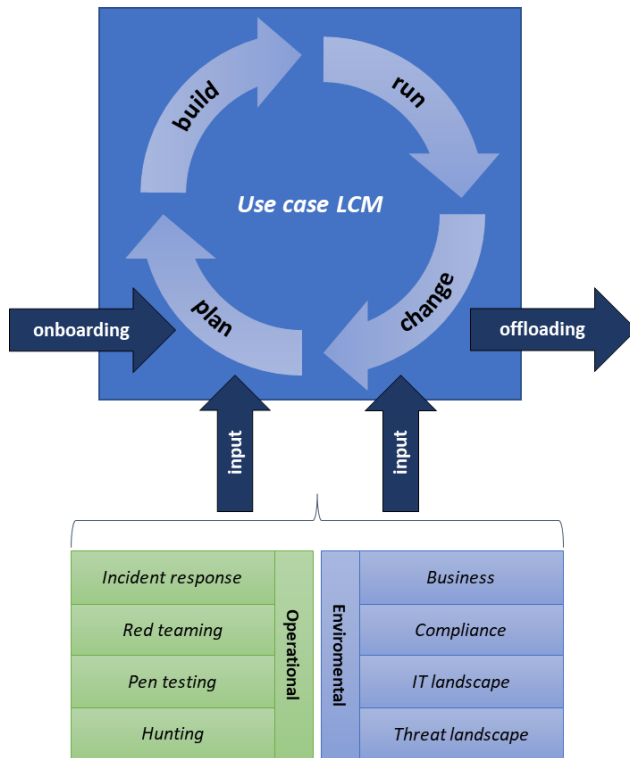


Figure 2: MaGMa lifecycle management

Within lifecycle management (LCM), it is particularly important to identify the right inputs: operational inputs (improvement initiatives arising from operational security activities) and environmental factors (both internal and external). These inputs support the maintenance of the existing set of use cases and the creation of new use cases when existing detection is insufficient.

2.3 MaGMa - Growth

The second element of MaGMa UCF is growth. MaGMa does not define a specific approach for this. Instead, it identifies the axes along which growth in completeness / maturity can be achieved. These axes are:

- **Breadth of the ruleset (horizontal axis).** This refers to how complete the ruleset is. The MaGMa structure can be used for this purpose, but coverage of MITRE ATT&CK® is also an excellent way to ensure the completeness of the ruleset. Bear in mind that, from a monitoring perspective, MITRE ATT&CK® sub-techniques are distinct techniques with distinct data sources. Combining MaGMa and MITRE ATT&CK® ensures that use cases that do not rely, or do not rely entirely, on MITRE ATT&CK® attack techniques are also included in the overview.
- **Depth of the ruleset (vertical axis).** This refers to the extent to which the use case can address different variations or manifestations of the attack it detects. An important question here is: "When is good good enough?" A rule with sufficient depth is effective at

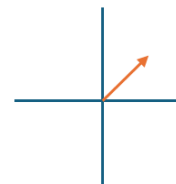
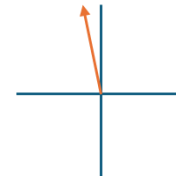
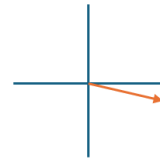
detecting the attack even when the attack technique is executed differently, for example from a different domain, IP address, filename or file location. Good detections focus on the essence of the technique, which remains the same regardless of how the attack manifests itself ^[2].

To manage growth in a controlled manner, it is necessary to establish a clear direction and set the right priorities.

2.3.1 Setting direction

As indicated, the completeness of the set of use cases can grow along 2 axes. Several strategies can be adopted:

- **Exclusively horizontal growth.** In this case, the focus is on expanding the ruleset to achieve completeness against a defined framework. With this strategy, the average depth (vertical axis) per rule decreases slightly. This is illustrated alongside the text.
- **Exclusively vertical growth.** In this case, the focus is on deepening the ruleset and detecting different variations of attack techniques. Here too, the average breadth per depth level decreases slightly with this strategy, as illustrated alongside the text.
- **A combination of horizontal and vertical growth.** In this case, rules are prioritised, and breadth or depth is increased as appropriate for the objectives. With this strategy, development proceeds in two directions simultaneously, as shown alongside the text. This strategy requires the organisation to be able to set these priorities.



2.3.2 Setting priorities

Growth in the set of use cases can be prioritised in several ways, each with a different basis:

- **Based on threats.** This involves examining which threat actors target the geography, sector and potentially the organisation itself. It can also involve identifying the most frequently used attack techniques. These techniques, and the use cases to which they belong, should receive the most attention. MITRE ATT&CK®, combined with up-to-date cyber threat intelligence (CTI), plays a central role in this prioritisation.
- **Based on existing controls.** The current set of controls, both technical and non-technical, forms the basis of the organisation's resilience to cyberattacks. Techniques often exploit missing, incorrectly configured or outdated (unpatched) controls. Identifying the existing controls and their quality establishes the organisation's protection profile. This also makes clear which attack techniques are likely to be most effective. MITRE DEF3ND™ plays a central role in this prioritisation.
- **Based on current data sources.** In a large or complex organisation, obtaining the right data at the right quality is often difficult. This also applies to managed security service providers, who depend on the data supplied by their customers and the associated contractual arrangements. Data quality and completeness ultimately determine the available monitoring capabilities. DeTT&CT plays a central role in this prioritisation.

² [Summitting the Pyramid v4.0.0 — Summitting the Pyramid v4.0.0 documentation](#)

The most targeted approach focuses on current threats for which existing controls are insufficient and data is available. In practice, this can be a complex approach. The starting point should always be an understanding of the most frequently used techniques. This information is available in the MITRE ATT&CK® dataset. From this starting point, the other elements can be used to add further nuance as needed and develop a more comprehensive approach.

2.4 MaGMA - Metrics & assessment

The third and final component of MaGMA is Metrics and assessment. This component aims to provide insight into the quality of the set of use cases. It defines 3 metrics: coverage, implementation and effectiveness. Two calculated values are then derived from these: weight and potential. The next chapter describes these metrics in the new model, as they differ from the interpretation in the original MaGMA. In addition to quality analysis using MaGMA metrics, detection quality can also be measured using DeTT&CT. However, this uses different quality criteria. Only the MaGMA criteria are used in this document.

3 MaGMA 2.0

Version 2.0 of MaGMA addresses the shortcomings identified in the introduction. It also introduces a different way of aggregating and calculating values that is more specific to individual risks and more closely aligned with how risks manifest themselves. This chapter follows the same structure as the previous chapter to make the differences clear.

3.1 Model

At its core, the MaGMA model has not changed: the 3 layers remain intact. Their content is slightly different, particularly at L1 (the business layer). Whereas the Cyber Kill Chain played a prominent role separate from risks in the original MaGMA model, MaGMA 2.0 adopts a model that incorporates the Unified Kill Chain and integrates it into the risk calculations.

The MaGMA 2.0 model is shown below (left), alongside the MaGMA 1.0 model (right) for comparison.

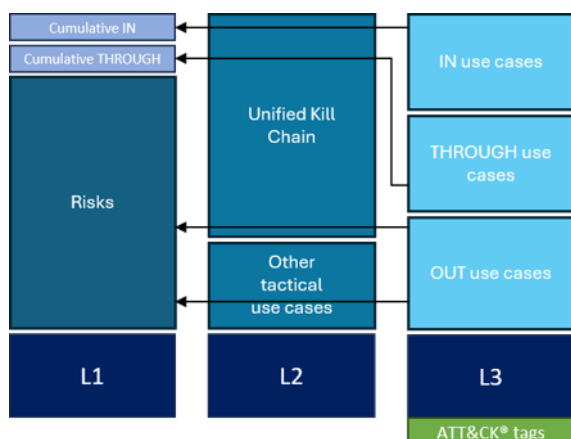


Figure 3: MaGMA 2.0 model

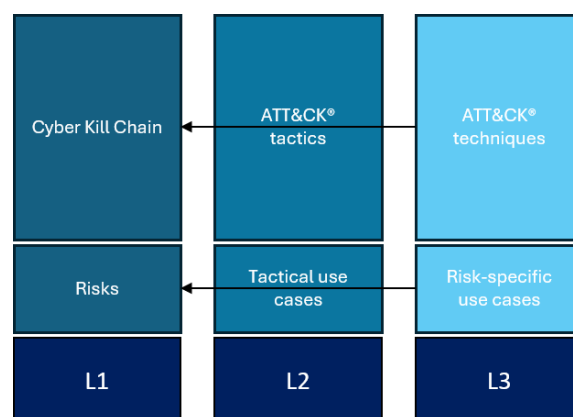


Figure 4: MaGMA 1.0 model

Several points stand out when comparing MaGMA 2.0 with MaGMA 1.0:

1. The L3 layer now distinguishes use cases based on the Unified Kill Chain phases: IN, THROUGH and OUT. Previously, the only distinction was between specific and non-specific use cases.
2. The L2 layer aggregates the Unified Kill Chain and provides a broader basis than the ATT&CK® tactics, because the Unified Kill Chain also includes tactics that do not appear in MITRE ATT&CK®. It also retains room for use cases unrelated to the kill chain, such as policy violations and compliance-related matters. This latter aspect is unchanged from MaGMA 1.0.
3. Risks account for a much larger share of L1 than in the previous model, in which the Cyber Kill Chain played a particularly prominent role. In practice, this often meant that more than 90% of the quality scores fell within a single phase of the Cyber Kill Chain, with most of these falling under 'actions on objectives'. In the new model, risks have a more prominent role, and the weighting includes scores for use cases that are not specific to an individual risk.

These changes make the new model more representative of the actual risk and enable it to take the phases of an attack into account.

3.1.1 Unified Kill Chain

As indicated, the Unified Kill Chain has become a central part of the MaGMA 2.0 design. The Unified Kill Chain describes an attack in 3 phases and 19 steps, as illustrated in the figure below:



Figure 5: Unified Kill Chain (source: *The Unified Kill Chain, raising resilience against advanced cyber attacks* [3])

The rationale for making the link to the kill chain less prominent at MaGMA's L1 layer is that, for a large part of the kill chain (the entire IN phase, the entire THROUGH phase and part of the OUT phase), the attacker's ultimate objective cannot yet be determined. This only becomes apparent at the end of the kill chain. Detections can therefore be divided into 2 types:

- **Early detection.** Detecting attacks early, before the attacker has achieved their objective. For many types of attack, this covers most of the attack.
- **Impact detection.** Detecting the actual objective of the attack. Examples include detecting file encryption (ransomware), exfiltration of sensitive information (data theft) and unauthorised access to highly classified intellectual property (espionage).

Within MaGMA 2.0, an aggregated score is assigned to IN and THROUGH. For OUT, a direct link is established to L1 risks (via specific tactics in the L2 layer) where possible and meaningful.

3.1.2 Calculations

Two types of calculation apply in MaGMA 2.0:

- **Aggregation.** Aggregation is essentially the addition of individual results, starting at L3. At L2, results are aggregated by adding together the results of the associated L3 rules. Aggregation also takes place at L1, both for risks and for the first 2 phases of the Unified Kill Chain. These are referred to as Cumulative IN and Cumulative THROUGH.
- **Calculation.** An additional calculation is performed for risks. This calculation is tailored to each risk by determining the relative proportions of IN, THROUGH and OUT. These proportions differ between a DDoS attack and a ransomware attack.

Aggregation is straightforward, automatic and non-configurable. The calculation can be configured for each defined risk. The configuration affects the final risk score. MaGMA 2.0 uses the following calculation:

³ [Unified Kill Chain: Raising Resilience Against Cyber Attacks](#)

Risk = 100% - ((cumulative IN * IN weight) + (cumulative THROUGH * THROUGH weight) + (aggregated OUT * OUT weight))

3.1.2.1 Example calculation: DDoS

At first glance, the calculation may seem complex. Two examples are therefore provided. The first is DDoS. For each calculation, the relative proportions of IN – THROUGH – OUT must be determined. These are expressed as percentages totalling 100%. For DDoS risk, the proportions might be as follows:

- **IN:** 5%. Only a small part of the attack falls under IN (initial compromise). Only reconnaissance falls within this phase.
- **THROUGH:** 0%. As there is no digital intrusion, the THROUGH phase does not apply to this risk.
- **OUT:** 95%. Most of the attack consists of a direct impact on online service delivery through the execution of the DDoS attack.

Assuming a cumulative IN score of 40%, a cumulative THROUGH score of 35% and a score of 85% for the rules specifically detecting DDoS, the risk can be calculated as follows:

$$\text{Risk} = 100\% - ((40\% * 5\%) + (35\% * 0\%) + (85\% * 95\%)) = 17\%$$

This indicates a 17% risk of failing to detect this risk, whether at an early stage or in the final phase. The risk is therefore relatively low and is mainly influenced by the specific detection of DDoS impact.

Note: 40% and 35% for cumulative IN and THROUGH respectively are relatively low scores. This means that the organisation's overall level of detection is low. This may result from poor visibility or coverage, poorly tuned rules, unvalidated rules or a combination of these factors.

3.1.2.2 Example calculation: ransomware

Ransomware attacks often follow the entire kill chain. For this risk, the proportions might be as follows:

- **IN:** 25%. Initial compromise is an important part of the attack. At this point, it is not yet clear that the attack involves ransomware: the objective is still unknown.
- **THROUGH:** 45%. Lateral movement and access to the right credentials are necessary to ultimately encrypt the most important systems. This forms the longest part of the attack and is therefore assigned the largest percentage. Here too, the objective of the attack is not yet clear.
- **OUT:** 30%. The remaining proportion is assigned to the OUT phase. This naturally includes encrypting core systems (impact), but is usually accompanied by exfiltration (and potentially collection) of information for multiple extortion.

Assuming the same cumulative IN and THROUGH scores as in the previous example, and a score of 65% for the rules specifically detecting ransomware and associated exfiltration, the risk can be calculated as follows:

$$\text{Risk} = 100\% - ((40\% * 25\%) + (35\% * 45\%) + (65\% * 30\%)) = 55\%$$

This indicates a significant risk of failing to detect this attack. In contrast to improving DDoS monitoring in the previous calculation, where the specific use cases have a particularly strong effect on the overall score, the organisation should focus primarily on improving the overall quality of monitoring in the THROUGH phase to reduce this risk.

3.2 Management & Growth

The new model makes no changes to use case lifecycle management or the growth of the use case library. The underlying principles remain the same. The description in the previous chapter also incorporates more recent insights into this subject.

3.3 Metrics & assessment

The metrics were reviewed for MaGMA 2.0, particularly because they were difficult to automate. The new model retains the same metrics but interprets them slightly differently. A key starting point in defining the new metrics is that they must be suitable for automation. The following basic principle is also applied: a detection rule functions well if it has the right data, is accurate and has been tested to confirm that it works correctly under different conditions.

Based on this principle, the metrics are defined as follows:

- **Coverage.** Also known as visibility. This metric indicates the extent to which the SOC has complete information to perform detection correctly. Coverage can be approached at 2 levels of detail:
 - **High level.** This simply considers what percentage of the relevant assets / data sources are connected to the monitoring environment. This can be automated by comparing the sources present with the total number of sources recorded in the CMDB. A prerequisite is that the CMDB accurately represents the environment. A comprehensive and mature asset management process is an important requirement here. Without such a process, there is no clear view of the completeness of controls (including monitoring), resulting in high-risk blind spots.
 - **Detailed level.** This considers coverage by mapping visibility using DeTT&CT. For each platform, DeTT&CT can show which attack techniques can be detected based on the availability of the right information (data components in MITRE ATT&CK®). The completeness of this information depends, for example, on the logging configuration. A quality dimension can also be added. DeTT&CT distinguishes 5 data quality indicators. These are not used by default in DeTT&CT assessments. It is advisable to include at least “device completeness”, combining asset coverage with detailed visibility. The full description of the DeTT&CT data quality indicators is included in Annex A.

Coverage / visibility is expressed as a percentage. Specifically, a score of 100% means that all data sources are connected (coverage) or all data components are available (visibility). When DeTT&CT is used, the percentage can be adopted by linking the technique to the detection rule using MITRE ATT&CK®. If multiple techniques are detected, the DeTT&CT outputs for both techniques should be combined into a single percentage (average).

- **Implementation.** Implementation describes how well the rule is implemented in the tooling. This metric has been reinterpreted as the rule's false positive ratio. A rule that generates many false positives receives a low score.

Detection logic	Malicious / non-malicious	Outcome	Description
Correct	Malicious	True positive	Detection of a genuine security incident
Correct	Non-malicious	Benign positive	Detection of a security event with a legitimate reason (e.g. a penetration test or an administrative action)
Incorrect	Malicious	False negative	A genuine incident that was not detected because of incorrect or incomplete detections
Incorrect	Non-malicious	False positive	An alert that should not have been generated

Specifically, the metric is expressed as the percentage of alerts classified as false positives relative to the total number of alerts for that detection rule. Benign positives can also be included, as tuning or allowlisting can sometimes prevent these alerts as well.

If detection rules have not generated any alerts during the past period (which is possible for highly specific alerts), they can be interpreted as 100% (no false positives). This naturally does not apply to rules that are expected to trigger regularly. For this type of rule, it is important to test thoroughly that the rule works correctly: effectiveness. Measuring effectiveness is explained below.

- **Effectiveness.** Effectiveness is determined by how low the likelihood of false negatives is: failing to detect an attack technique because the rule is incorrect or incomplete. To reduce the likelihood of false negatives, it is important to test whether the rule works correctly (detection validation). Detection validation can take different forms, from fully manual testing to largely automated testing using purpose-built tools.

The following table is used for scoring:

Percentage	Description
20%	Untested rule
30%	Tested against existing data during development and/or release
40%	Tested and reactively updated based on analyst feedback
60%	Tested during development and updates, with occasional tests using simulated data (log injection)
95%	Tested during development and updates, with regular testing by red teams and other types of attack simulation (event generation)
100%	Regularly tested by red teams using automated tools (such as Breach & Attack Simulation (BAS) tools) with variations of techniques

In addition to the 3 basic metrics above, MaGMA includes 2 metrics calculated from them: weight and potential.

- **Weight.** Weight is the detection rule's overall score, calculated by multiplying the percentages of the 3 metrics above. The result is again a percentage:

$$weight = visibility (\%) * implementation (\%) * effectiveness (\%)$$

Because percentages are multiplied, a detection rule's score quickly becomes low when one of the metrics has a low value. For example, if all quality indicators score 75%, the overall score is only 42% (75% of 75% of 75%).

- **Potential.** Potential indicates how much the rule can be improved. The higher the potential value, the greater the scope for improvement. Unlike potential in MaGMA 1.0, potential in MaGMA 2.0 is the inverse of weight:

$$potential = 100\% - weight$$

This value can be used to prioritise improvement initiatives. This can be done simply by addressing the rules with the greatest potential first. A more risk-based approach is also possible by first identifying which rules are most important to the organisation.

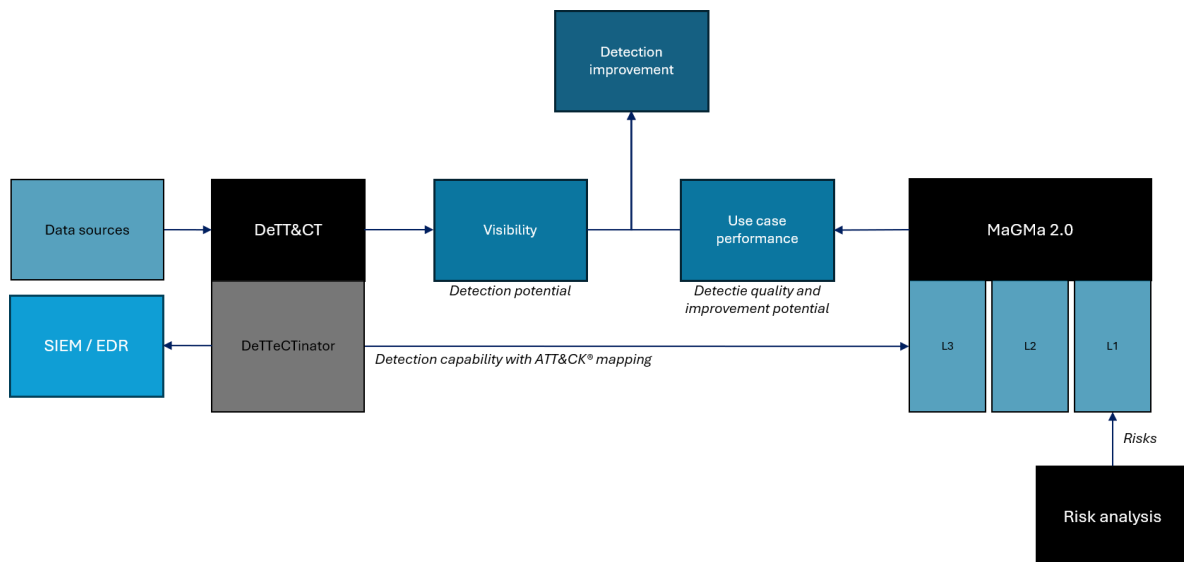
It is important to note that these metrics can be presented for the different MITRE ATT&CK® domains. For example, a separate score can be determined for the ICS (OT) domain, enabling a specific improvement plan for the quality and completeness of monitoring within that domain.

3.4 Interrelationships

MaGMA 2.0 establishes clear relationships between several activities:

- Identifying risks (risk analysis)
- Mapping visibility (DeTT&CT)
- Assessing detection quality (MaGMA)

These relationships are shown in the figure below.



During the development of MaGMA 2.0, MaGMA / DeTT&CT assessments were combined with SOC-CMM assessments. This provides an integrated view of both maturity across the breadth of the SOC and capability in depth, specifically in security monitoring and the associated detection engineering activities. A SOC-CMM assessment also covers topics such as use case management (which may be addressed using MaGMA), visibility (which may be addressed using DeTT&CT) and detection engineering (which underpins the development of detection rules and the management of detection and data quality).

3.4.1 Risk analysis

Risk analyses are the main input at MaGMA's L1 level. Risk analysis identifies risks for which security monitoring can be used to reduce the risk. These include general cybersecurity risks (such as ransomware and DDoS) as well as organisation-specific risks, such as sabotaging operational technology, stealing intellectual property or accessing and/or publishing confidential data. For each L1 risk, there are L2 and L3 use cases that can be linked directly. The overall state of monitoring is also a factor.

3.4.2 Visibility

Visibility is assessed for each platform (e.g. Windows servers or Windows endpoints) using DeTT&CT. It is important to recognise that DeTT&CT operates at a highly detailed level. Detailed insight into the configuration of the data sources is required. The DeTT&CTinator tool supports this in 2 ways:

- Reading data sources to map visibility. This output can be used as a metric at L3.
- Reading the SIEM to identify detection rules. This output can be used to populate L3 with detection rules and ATT&CK® mappings.

The tool can therefore support the automation of assessments.

3.4.3 Detection quality

Detection quality is measured using MaGMA, as described earlier in this chapter. This shows how well the set of detection rules performs. Linking this information to visibility information provides insight into how the set of detection rules can be improved.

The PRISMA tool (next chapter) links DeTT&CT and MaGMA wherever possible. This provides the highest degree of automation. As indicated in section 3.3, general coverage based on the CMDDB is used when DeTT&CT data is unavailable. The calculation of this coverage can also be automated to a large extent.

3.5 Development

Like MaGMA 1.0, MaGMA 2.0 was developed collaboratively. A cross-sector working group was established to develop the model. Its input was used to shape the new model and its underlying methodology, and to verify the relevance of the results. In addition to developing the model and methodology, a pilot was conducted to determine whether the theory could be successfully applied in practice. This pilot involved several security operations centres within the Dutch central government.

The PRISMA tool was developed with funding from the Dutch central government. Continually improving cyber resilience is of strategic importance to the Dutch central government. Government policy also supports adopting open standards and open-source tools and encouraging their use.

4 Limitations and best practices

4.1 Current limitations

Several limitations have been identified in the current implementation of MaGMA 2.0 and PRISMA:

1. The current PRISMA tool is not yet suitable for importing data in bulk. Manual editing, including bulk editing, is also limited. An Excel import file is therefore supplied for initial bulk imports. This Excel file supports only Enterprise ATT&CK® techniques (not Mobile or ICS).
2. MaGMA does not currently support detection rules that map to multiple MITRE tactics or techniques. This may occur with 'multi-stage' detections. In these cases, the detection rule must be split into multiple MaGMA L3 use cases, each with its own link to an L2 use case.
3. There is limited support for representing detection rules outside traditional SIEM detection, such as EDR and UEBA. There is currently no solution for this.
4. PRISMA cannot display DeTT&CT and MaGMA assessments with different scopes simultaneously. This means that only 1 DeTT&CT assessment can be active and linked to use cases (visibility) at any time.
5. An individual metric cannot be disabled for a use case. For example, if no false positive data is available for a particular use case, this metric must be set to 100%. This is because the weight calculation multiplies percentages. A value of 0% always results in a final score (weight) of 0%.
6. The PRISMA tool uses MITRE ATT&CK® version 17.1. The changes required for compatibility with versions >18 have not yet been implemented.
7. Custom threat actors cannot currently be added to the list; only the default actors are supported.
8. Individual detection rules (L3) cannot be weighted. This means that all L3 rules are equally important and contribute equally to the overall score.
9. The tool does not support multi-select for use cases. It is therefore not possible to change multiple values or delete multiple rules at once. When working with large numbers of use cases, it is useful to prepare the rules in the Excel file.

Further development of the tool is required to address these limitations.

4.2 Best practices for conducting an assessment

The following best practices were identified during the pilot:

- A MaGMA UCF assessment should be preceded by a discussion about the scope of the SOC. Where there are substantial OT and IT environments, a partially separate assessment should be performed for each technology domain (IT, OT).
- DeTT&CT assessments are time-consuming. It is therefore important to choose carefully which platforms (e.g. Windows clients or Linux servers) to assess for visibility.
- MaGMA assessments sometimes require estimates when the right data is unavailable. It is important to state explicitly where estimates have been used and their approximate reliability.
- All decisions made during an assessment must be properly documented, including the scope of DeTT&CT, whether use cases without MITRE mappings are included, and how

multi-stage detections have been handled. This provides accountability for the results and makes the assessments repeatable.

- When there is insufficient time to assess individual rules (for example, for the testing strategy), it may be useful to create use case categories and assign a score to each category as a whole. In the tool, this means assigning the same value to all use cases within a category. The tool does not support categories, so these must be defined outside PRISMA.
- Use DeTT&CT scores wherever possible, as these provide a greater level of detail than estimates or asset coverage calculations using asset management tools.
- Time and level of detail are often in direct opposition, including in these assessments. Determine the focus in advance. This allows you to establish where the highest level of detail is required and where a lower level is sufficient. These decisions should also be documented.
- The separate Excel file can be used to link L3 rules to L2 rules automatically. It also makes it easier to edit and organise use cases in bulk. Appropriate preparation before importing can save considerable time afterwards.
- Use automated metrics wherever possible. Manual work makes the process labour-intensive and less repeatable. If this requires compromises in the level of detail of a metric, these may be acceptable. This decision must be taken at SOC management level or above.

5 PRISMA Tool

The Prioritized Risk Indicator for Security Monitoring & Analysis (PRISMA) tool was developed to support the methodology. It provides insight and direction for detection engineers and management. The tool is available on GitHub: <https://github.com/jongstra/prisma/>

5.1 PRISMA tool components

The tool has 2 main components:

1. **DeTT&CT visualisations.** The PRISMA tool can read DeTT&CT YAML files and generate visualisations directly from them. These visualisations immediately show the visibility scores against the MITRE ATT&CK® framework. An overview is provided for the different ATT&CK® domains (Enterprise, Mobile and ICS).

This part of the tool also provides filtering options. These filters can be used to:

- view specific actors and the techniques they use
- filter by specific techniques
- filter by specific data components
- filter by visibility and occurrence scores (how often attackers use a technique)

Finally, this part of the tool includes an INSIGHTS section. These insights can be used to guide improvements in visibility. They include:

- Visibility scores by MITRE ATT&CK® tactic
- Statistics from the ATT&CK® dataset, including total numbers of techniques and sub-techniques, the most capable attackers and the most common techniques
- Suggestions for improvement. This chart indicates which data component adds the most value in improving visibility for the platform assessed.

An important caveat is that DeTT&CT operates per platform and therefore does not provide an overall score for the entire infrastructure. The tool currently supports 1 state at a time; scores for multiple platforms cannot be loaded simultaneously.

2. **MaGMA visualisations.** This part of the tool directly supports the MaGMA methodology. Defining and loading the L1, L2 and L3 layers enables the tool's calculations to generate aggregated and calculated scores. These scores can then be used to improve detection. If a DeTT&CT YAML file has been loaded, it can be linked to the L3 rules. If the DeTT&CT score relates to a different platform from the use cases (e.g. the score was calculated for Windows endpoints but the use case concerns Linux servers), the link can be removed.

In addition to the core section containing the use cases, metrics, scores and calculations described in the previous chapter, this part of the tool includes visualisations: a heatmap and insights.

The heatmap represents the MITRE ATT&CK® framework with the scores of individual rules incorporated. It is based on the L3 use cases and their MITRE ATT&CK® mappings. Here too, filters can be applied for specific groups or score percentages.

The insights summarise the MaGMA scores and help determine the next steps. The following insights are provided:

- The number of use cases at each layer (L1, L2, L3), showing the distribution of use cases.
- Average visibility (coverage), implementation and effectiveness for each data source. These insights help identify data sources (e.g. Windows servers, firewalls or the cloud environment) that are lagging in detection quality and require more attention.
- The most common attack techniques in the detection ruleset
- L3 use cases with the highest improvement potential
- Improvement potential visualised for each L1 use case. This makes it possible to determine, for each risk, whether it is most useful to invest in expanding visibility (coverage / visibility), tuning rules (implementation) or testing rules (effectiveness).

These insights make the quality of the set of detections clear across several axes and show where efforts should be directed to bring risks to an acceptable level.

Examples of the visualisations are included in Annex B.

5.2 Saving and exporting

The tool contains a large amount of information. For DeTT&CT, it uses standard DeTT&CT YAML files. These can be generated using the dedicated tool or other automated methods (including DeTTeCTinator). For MaGMA, the state can be saved and loaded in YAML format. Data can be imported into the tool using a supporting Excel file in which the use cases at different levels are linked.

Further explanation is available in the PRISMA tool's technical documentation.

6 Annex A: DeTT&CT data quality indicators

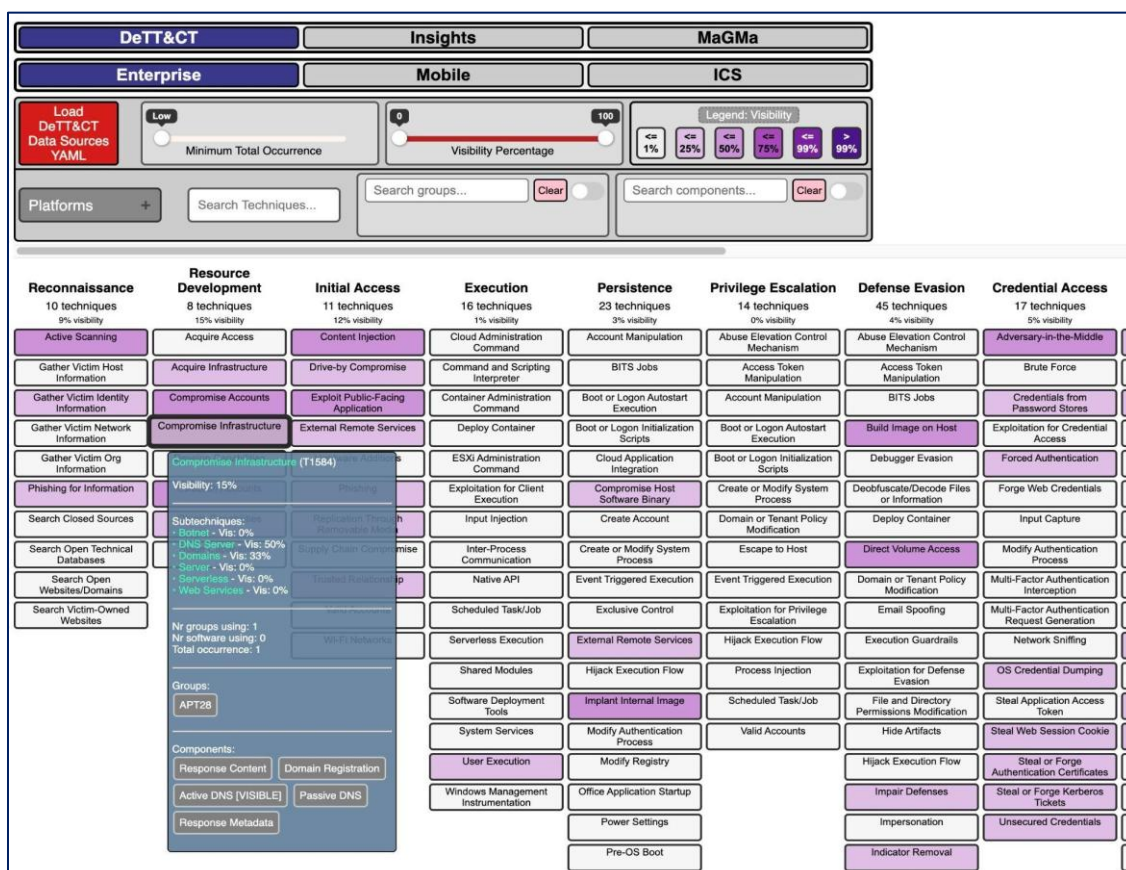
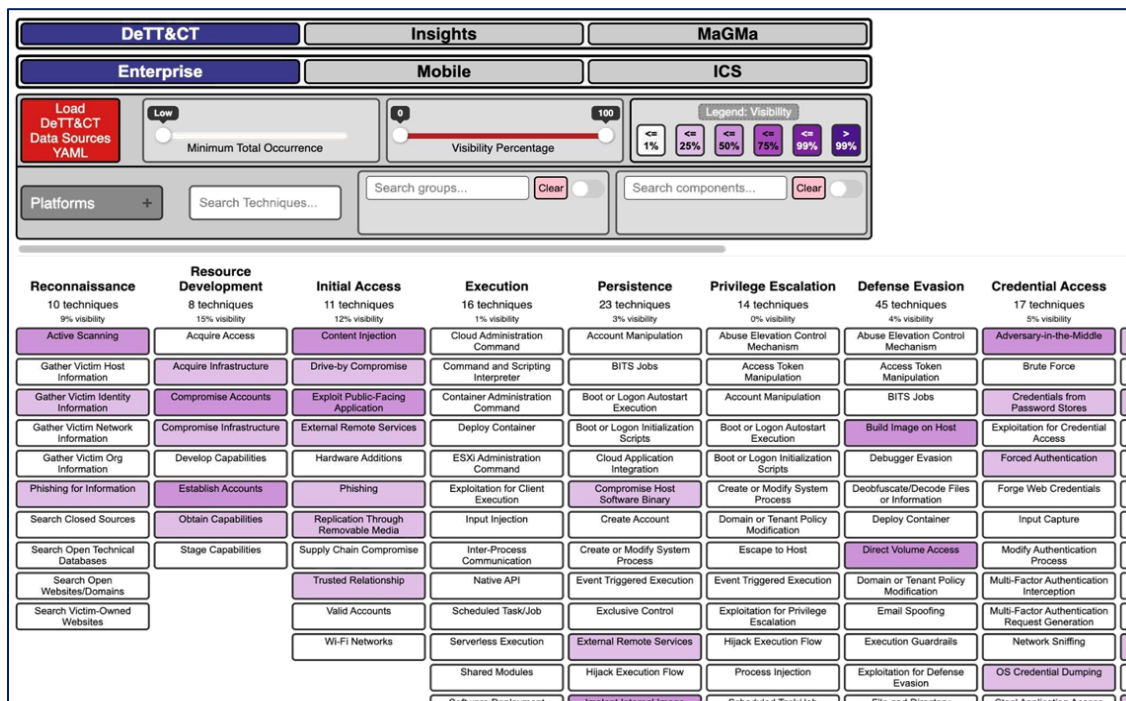
The following table describes the DeTT&CT data quality indicators. The text is retained in its original English.

Indicator	Description	Question	Example
Device completeness	Indicates if the required data is available for all devices.	When doing a hunting investigation can we cover all devices/users that we need to?	We are missing event data for endpoints running an older version of Windows.
Data field completeness	Indicates to what degree the data has the required information/fields, and to what degree those fields contain data.	Are all the required data fields in the event present and contain data to perform my investigation?	We have proxy logs, but the events do not contain the "Host" header.
Timeliness	Indicates when data is available, and how accurate the timestamps of the data are in relation to the actual time an event occurred.	Is the data available right away when we need it? Do the timestamps in the data represent the time the record was created or ingested?	We have a delay of 1-2 days to get the necessary data from all endpoints into the security data lake. Timestamps are representing not the time an event occurred, but ingestion time in the security data lake.
Consistency	Says something about the standardisation of data field names and types.	Can we correlate the events with other data sources? Can we run queries across all data sources using standard naming conventions for specific fields?	Field names within this data source are not in line with that of other data sources.
Retention	Indicates how long the data is stored compared to the desired data retention period.	For how long is the data available? How long do you want to keep the data?	Data is stored for 30 days, but we ideally want to have it for 1 year.

Annex B: PRISMA tool visualisations

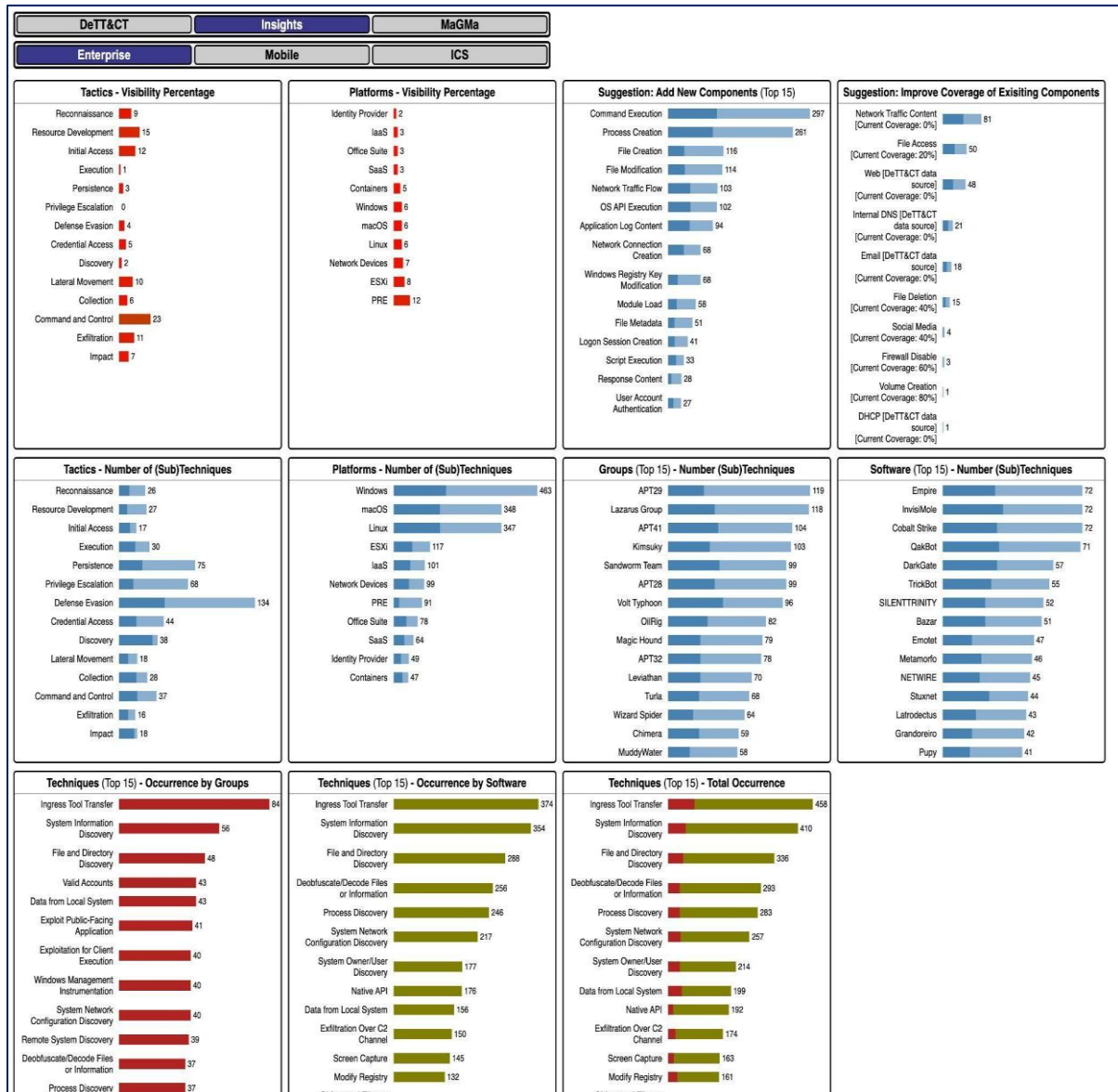
DeTT&CT heatmap

The figure below shows the DeTT&CT heatmap and its filtering options, followed by a heatmap displaying the details for 1 technique.



DeTT&CT Insights

The figure below shows the insights from a DeTT&CT assessment.



MaGMA L1, L2, L3

The L1, L2 and L3 levels are shown below, respectively.

DeTT&CT			Insights		MaGMA									
Enterprise			Mobile		ICS									
L1	L2	L3	Heatmap	Insights	Summary	Load MaGMA YAML	Save MaGMA YAML							
	ID	Use Case Name	Description	L2 UC Related	L3 UC Related	Visibility %	Implementation %	Effectiveness %	Weight %	Potential %	IN Impact %	THR Impact %	OUT Impact %	Risk
	IN	Cumulative IN risk	Cumulative risk of IN stages and techniques, serving as a risk amplifier for the business risks.	4	33	55.72	23.64	53.62	15.11	84.89				
	THR	Cumulative THROUGH risk	Cumulative risk of THROUGH stages and techniques, serving as a risk amplifier for the business risks.	34	133	57.59	33.82	54.03	23.12	76.88				
	DOS	Denial of Service	Any Denial of Service attack, optionally distributed with the goal of causing outages.	1	6	0.00	0.00	0.00	0.00	100.00	80	10	10	85.60
	ESP	Espionage / Data Theft	Corporate espionage aimed at stealing proprietary intellectual property.	77	253	27.35	18.40	32.80	12.67	87.33	30	40	30	82.42
	CEO	CEO Fraud	Attempts by criminals to impersonate the organization's CEO or other board-level executive and	12	27	0.00	0.00	0.00	0.00	100.00	60	20	20	86.31
	EXT	Extortion / Ransomware		6	28	0.00	0.00	0.00	0.00	100.00	40	20	40	89.33
	SAB	Sabotage / Destruction	Any action to destroy/damage organizational and personal asset, information or reputation with the	18	82	45.63	27.08	39.58	17.81	82.19	30	50	20	80.34
	INS	Insider Threat		4	7	0.00	0.00	0.00	0.00	100.00	20	40	40	87.73
	POL	Policy Violations	Illegal sites, service account usage, presence of vulnerabilities, Unauthorized	64	93	0.00	0.00	0.00	0.00	100.00	30	40	30	86.22
Averages →						20.70	11.44	20.00	7.64	92.36				
+ ADD NEW USE CASE +														

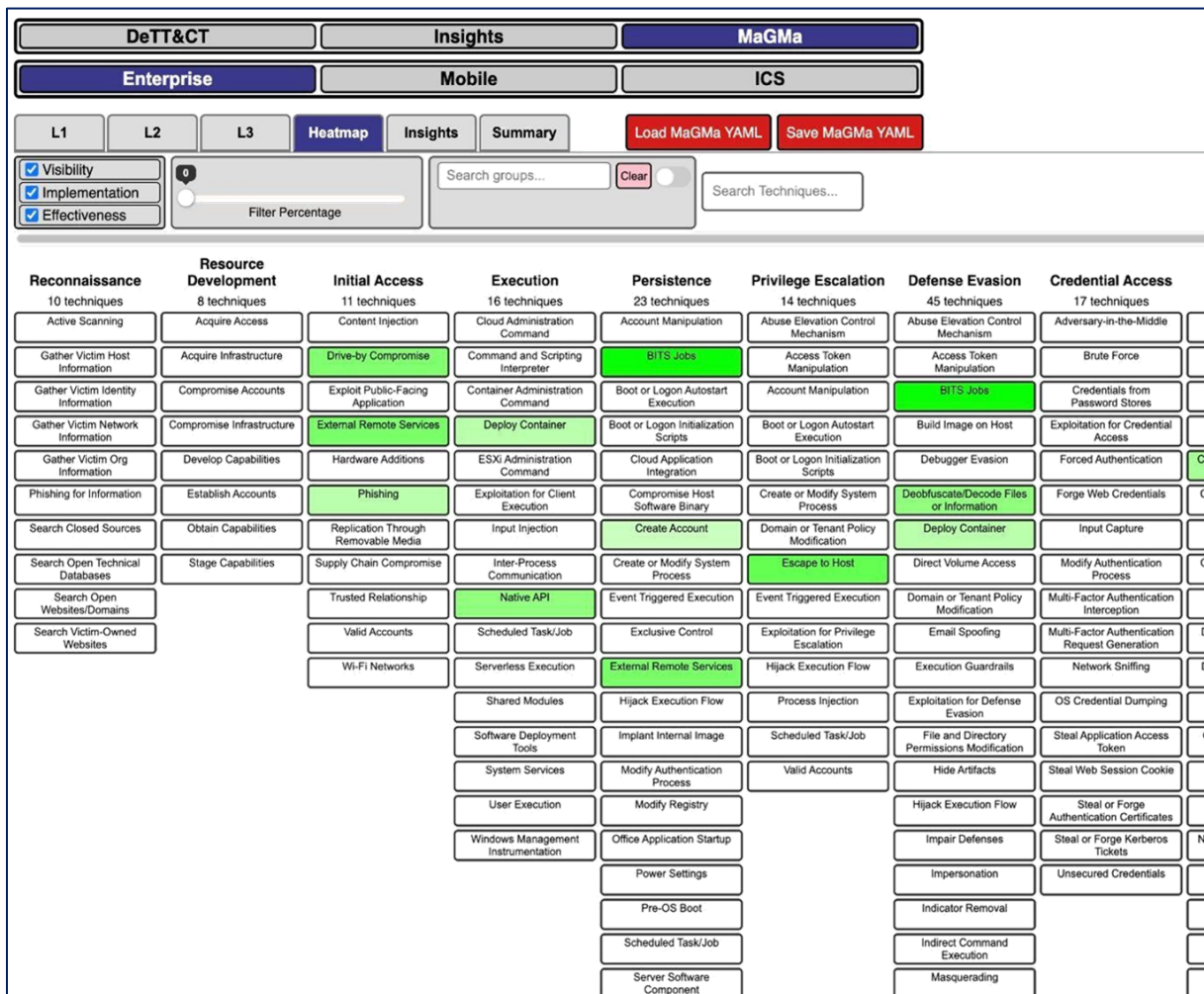
DeTT&CT		Insights		MaGMA							
Enterprise		Mobile		ICS							
L1	L2	L3	Heatmap	Insights	Summary	Load MaGMA YAML		Save MaGMA YAML			
	ID	Use Case Name	Description		Parent Use Case	L3 UC Related	Viability %	Implementation %	Effectiveness %	Weight %	Potential %
	IN-REC	Reconnaissance			IN Cumulative IN risk 	3	51.80	20.00	90.00	5.94	94.06
	IN-RES	Resource development			IN Cumulative IN risk 	12	85.00	48.33	86.67	36.45	63.55
	IN-DEL	Delivery			IN Cumulative IN risk 	4	0.00	0.00	0.00	0.00	100.00
	IN-SOC	Social Engineering			IN Cumulative IN risk 	8	0.00	0.00	0.00	0.00	100.00
	IN-EXP	Exploitation			IN Cumulative IN risk 	9	90.67	60.00	74.00	37.80	62.20
	IN-PER	Persistence			IN Cumulative IN risk 	3	92.40	47.60	78.00	31.43	68.57
	IN-DEF	Defense Evasion			IN Cumulative IN risk 	5	93.40	25.09	81.32	16.82	83.38
	IN-CNC	Command & Control			IN Cumulative IN risk 	59	88.26	11.74	72.61	7.75	92.25
	IN-PHY	Physical compromise			IN Cumulative IN risk 	23	0.00	0.00	0.00	0.00	100.00
	THR-PIV	Pivoting	Tunneling traffic through a controlled system to other systems that are not directly accessible.		THR Cumulative THROUGH risk 	18	0.00	0.00	0.00	0.00	100.00
	THR-DIS	Discovery	Techniques that allow an attacker to gain knowledge about a system and its network environment.		THR Cumulative THROUGH risk 	2	82.75	53.33	80.00	34.35	65.65
	THR-PRI	Privilege Escalation	The result of techniques that provide an attacker with higher permissions on a system or network.		THR Cumulative THROUGH risk 	11	0.00	0.00	0.00	0.00	100.00
	THR-EXE	Execution	Techniques that result in execution of attacker-controlled code on a local or remote system.		THR Cumulative THROUGH risk 	27	87.44	53.59	89.49	43.92	56.08

DeTT&CT		Insights		MaGMA								
Enterprise		Mobile		ICS								
L1	L2	L3	Heatmap	Insights	Summary	Load MaGMA YAM		Save MaGMA YAM				
	ID	Use Case Name	Description	Parent Use Case	Data Source	ATT&CK Technique	Override	Visibility %	Implementation %	Effectiveness %	Weight %	Potential %
	IN-DEF-1	1		IN-DEF: Defense Evasion	Example DS 1	T1653: Power Settings		0.00	42	87	0.00	100.00
	IN-PER-1	2		IN-PER: Persistence	Example DS 1	T1020: Automated Exfiltration		54	54	84	24.49	75.51
	IN-DEF-2	3		IN-DEF: Defense Evasion	Example DS 1	T1621: Multi-Factor Authentication Request Generation		43	100	56	24.08	75.92
	IN-PER-2A	4 - A		IN-PER: Persistence	Example DS 2	T1020: Automated Exfiltration		12	43	32	1.65	98.35
	IN-PER-2B	4 - B		IN-PER: Persistence	Example DS 2	T1621: Multi-Factor Authentication Request Generation		54	76	78	32.01	67.99
	IN-DEF-3	5		IN-DEF: Defense Evasion	Example DS 3	T1005: Data from Local System		76	45	100	34.20	65.80
	THR-EXE-1	6		THR-EXE: Execution	Example DS 3	T1649: Steal or Forge Authentication Certificates		2.86	36	36	0.37	99.63
	IN-PER-3	7		IN-PER: Persistence	Example DS 3	T1653: Power Settings		67	84	12	6.75	93.25
	IN-DEF-4	8		IN-DEF: Defense Evasion	Example DS 3	T1025: Data from Removable Media		0.00	76	23	0.00	100.00
	IN-DEF-5	9		IN-DEF: Defense Evasion	Example DS 3	T1659: Content Injection		12	85	82	8.36	91.64
	THR-CRE-1A	10 - A		THR-CRE: Credential Access	Example DS 4	T1049: System Network Connections Discovery		22	0	36	0.00	100.00
	IN-PER-4A	11 - A		IN-PER: Persistence	Example DS 4	T1656: Impersonation		54	23	75	9.32	90.69
	IN-PER-4B	11 - B		IN-PER: Persistence		T1008: Exploitation for Privilege Escalation		87	12	37	3.86	96.14

The link to DeTT&CT is visible at L3. Where the checkbox is not selected, the DeTT&CT score is used. The link to ATT&CK® is also shown through tags.

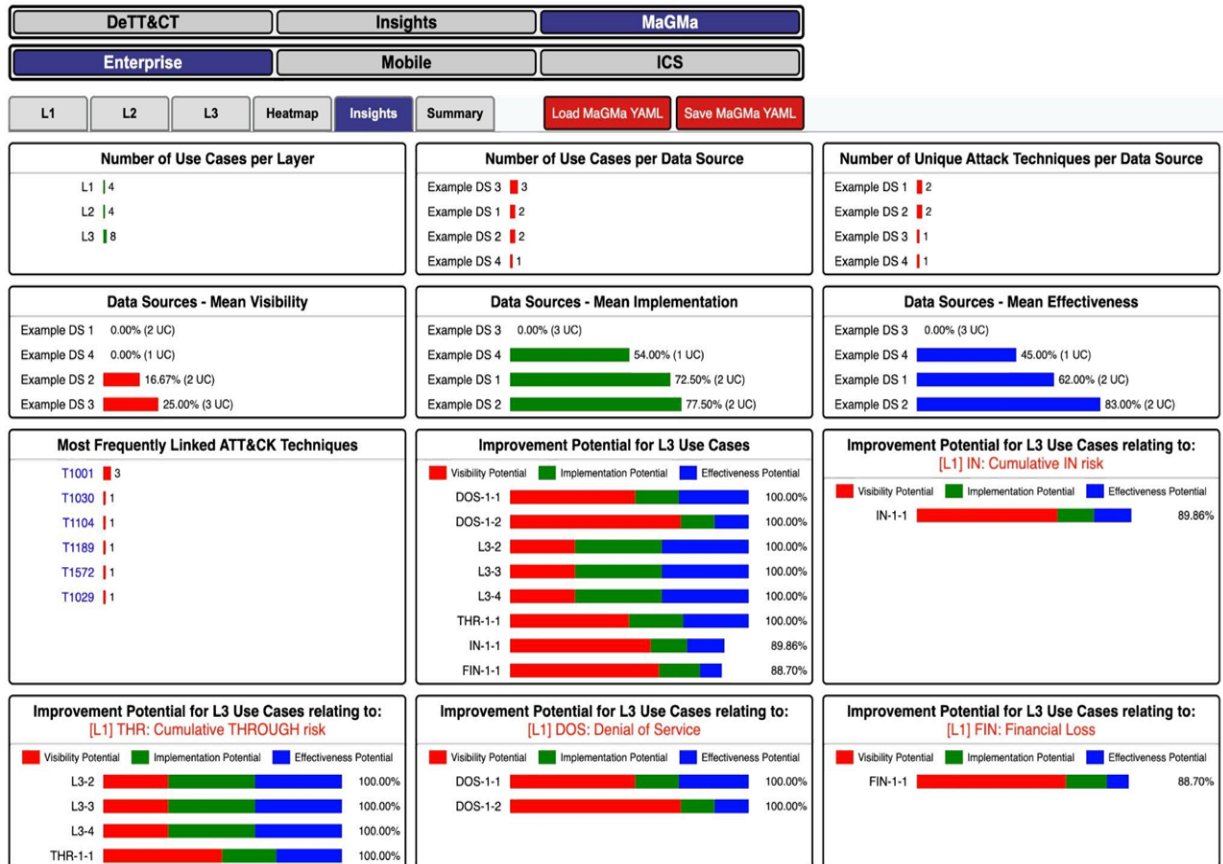
MaGMa heatmap

The heatmap below is generated from the information at L3 and the mapping of L3 use cases to MITRE ATT&CK® through tags.



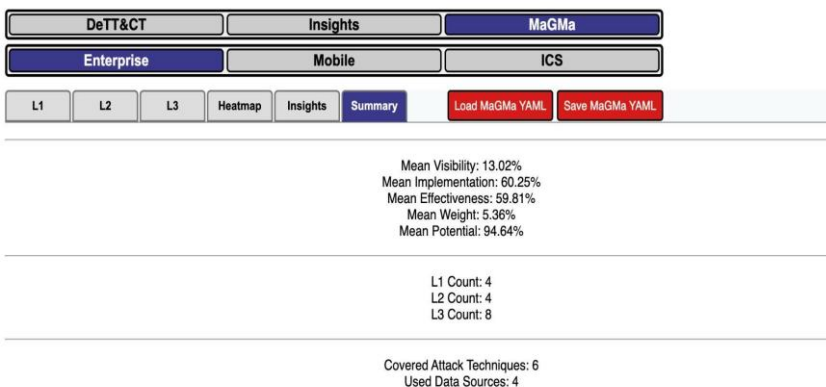
MaGMA Insights

The MaGMA insights are shown below: overall, by data source and by L1 use case.



MaGMA summary

Finally, the MaGMA summary provides an overview of the overall scores.



MaGMa 2.0

Use case framework

This publication is licensed under a Creative Commons BY-SA 4.0 License

You are free to:

- **Share** — copy and redistribute the material in any medium or format for any purpose, even commercially.
- **Adapt** — remix, transform, and build upon the material for any purpose, even commercially.
- The licensor cannot revoke these freedoms as long as you follow the license terms.

Under the following terms:

- **Attribution** — You must give appropriate credit, provide a link to the license, and indicate if changes were made. You may do so in any reasonable manner, but not in any way that suggests the licensor endorses you or your use.
- **ShareAlike** — If you remix, transform, or build upon the material, you must distribute your contributions under the same license as the original.
- **No additional restrictions** — You may not apply legal terms or technological measures that legally restrict others from doing anything the license permits.

For the full license description, see:

<https://creativecommons.org/licenses/by-sa/4.0/>